

Security Incident Report: Malicious Website Redirect via Brute Force Attack

Case study completed as part of the Google Cybersecurity Professional Certificate

Table des matières

Scenario.....	1
Network Protocol Identification.....	1
Incident Documentation	1
Recommended Remediation for Brute Force Attacks	2

Scenario

yummyrecipesforme.com, a website that sells recipes and cookbooks, was compromised by a former employee who gained access to the site's administrative panel through a brute force attack against a default password. The attacker injected JavaScript into the site's source code that prompted visitors to download and run a malicious file, then changed the administrative password to lock out the legitimate owner. Customers who ran the file were redirected to a fake copy of the site, greatrecipesforme.com, and reported that their computers began running slowly afterward. Analysts investigated the incident using a sandbox environment and the tcpdump packet capture tool.

Network Protocol Identification

The protocol involved in the security incident is the Hypertext Transfer Protocol (HTTP), operating at the application layer of the TCP/IP model. Since the issue centered on loading a web page from yummyrecipesforme.com and being redirected to a second web page at greatrecipesforme.com, the relevant traffic is the request and delivery of web content, which is carried out using HTTP. This is confirmed directly in the tcpdump log: each request to a website begins with a TCP three-way handshake (SYN, SYN-ACK, ACK) on port 80, followed by a packet explicitly labeled "HTTP: GET / HTTP/1.1" once the client requests the page. The malicious file that compromised end users' computers, and the subsequent redirect to greatrecipesforme.com, were both delivered to the browser over this same HTTP connection.

Incident Documentation

Several customers contacted the yummyrecipesforme.com helpdesk, stating that when they visited the website, they were prompted to download and run a file that claimed to provide access to new recipes. Customers reported that their personal computers had been running slowly since running the file. Separately, the website owner attempted to log in to the web server's administrative account and found that they were locked out.

A cybersecurity analyst opened the website in a sandbox environment to avoid impacting the company network, and ran tcpdump to capture the network traffic generated while interacting with the site. Upon loading yummyrecipesforme.com, the analyst was prompted to download a file advertised as a browser

update. The analyst accepted the download and ran the file, after which the browser redirected to a different website, greatrecipesforme.com.

Review of the tcpdump log confirmed this sequence of events. The client machine first sent a DNS request for yummyrecipesforme.com, which resolved to IP address 203.0.113.22. The client completed a TCP three-way handshake with that address on port 80, then sent an HTTP GET request, after which a large volume of HTTP traffic followed as the page loaded. Several minutes later, without further input from the analyst, the client sent a second DNS request, this time for greatrecipesforme.com, which resolved to a different IP address, 192.0.2.17. The client then completed a new TCP handshake with this second address, using a different source port than the original connection, and sent another HTTP GET request, followed again by a large volume of traffic. This pattern in the log is consistent with the browser being redirected from the legitimate site to the fake one shortly after the malicious file was executed.

A senior cybersecurity analyst reviewed the source code of the yummyrecipesforme.com website and the downloaded file. The review found that JavaScript had been added to the site prompting visitors to download a file disguised as a browser update, and that the file itself contained a script that redirected the browser to greatrecipesforme.com. Given that the website owner reported being locked out of the administrative account, the team assessed that the attacker used a brute force attack against the account's default password to gain access, then changed the password to prevent the legitimate owner from regaining control. The execution of the malicious file is what compromised the affected end users' computers.

Recommended Remediation for Brute Force Attacks

Primary recommendation: Implement two-factor authentication (2FA) on the administrative account.

MFA is the most effective single measure to prevent this type of incident because it directly addresses the root cause: the attacker was able to log in simply by guessing the default password. Even if a password is weak, reused, or guessed through repeated attempts, MFA requires a second form of verification, such as a one-time code sent to a trusted device, before access is granted. This means that a correctly guessed password alone would not have been enough for the attacker to reach the admin panel.

Supporting measures: Additional supporting measures, such as enforcing a strong password policy (minimum length, character requirements, no default or reused passwords), limiting the number of failed login attempts, and requiring a second person to validate changes to the website's source code, would further reduce the risk of similar attacks in the future.

Disallowing the reuse of previous passwords, including default passwords, would prevent an account from ever being secured by a password already known to be weak or exposed. Requiring more frequent password updates would further reduce the window in which a guessed or leaked password remains valid. Together with two-factor authentication, these measures address both the immediate vulnerability that led to this incident and the broader risk of credential-based attacks in the future.